

Develop a Security Policy Document for a Hypothetical SME Based on ISO/IEC 27001, and Perform a NIST-Aligned Risk Assessment

Case Study: Nexora Solutions Pvt Ltd (Hypothetical SME)

1. Information Security Policy

1.1 Purpose & Scope

1.1.1 This Information Security Policy (“the Policy”) establishes the principles and controls by which Nexora Solutions Pvt Ltd (“Nexora” or “the Company”), a 40-employee software consultancy, protects the confidentiality, integrity, and availability of its own information assets and those of its clients.

1.1.2 The Policy applies to all employees, contractors, and third parties who access Nexora's systems, networks, source code repositories, or client data, regardless of location or device ownership.

1.1.3 This Policy is aligned with the control objectives of ISO/IEC 27001:2022 Annex A and the NIST Cybersecurity Framework, and is reviewed annually or upon any significant change to the Company's technology environment.

1.2 Access Control Policy

Reference: ISO/IEC 27001 Annex A.9 (Access Control) and NIST SP 800-53 AC control family.

1.2.1 Access to information systems shall be granted on the principle of least privilege — employees are provisioned only with the access required to perform their current role.

1.2.2 Role-Based Access Control (RBAC) shall be implemented for all business-critical systems, including source code repositories, cloud infrastructure, and the customer relationship management (CRM) platform.

1.2.3 User accounts shall be provisioned within one business day of an employee's start date and de-provisioned (disabled and later removed) within 24 hours of employment termination or role change that no longer requires the access held.

1.2.4 Multi-Factor Authentication (MFA) is mandatory for all accounts with administrative, privileged, or remote-access capability, including VPN, cloud consoles, and source control platforms.

1.2.5 Access rights shall be reviewed quarterly by system owners, with findings documented and any excessive privileges revoked.

1.3 Password Policy

Reference: NIST SP 800-63B Digital Identity Guidelines.

1.3.1 Passwords shall be a minimum of 12 characters in length. Complexity composition rules (mandatory special characters, forced substitutions) are not required, in line with current NIST guidance, provided the minimum length is met.

1.3.2 Periodic forced password rotation is not required for standard user accounts; passwords shall instead be changed immediately upon any suspected or confirmed compromise.

1.3.3 All privileged and administrative accounts require Multi-Factor Authentication in addition to a password, with no exceptions.

1.3.4 Employees are required to use an approved password manager for generating and storing credentials; the reuse of passwords across personal and Company systems is prohibited.

1.3.5 Passwords shall never be transmitted or stored in plaintext, including in emails, chat messages, source code, or configuration files.

1.4 Incident Reporting Policy

Reference: ISO/IEC 27001 Annex A.16 (Information Security Incident Management).

1.4.1 Any suspected or confirmed information security incident — including but not limited to malware infection, unauthorized access, lost devices, or phishing attempts — must be reported to the IT Security Lead immediately, and in no case later than one hour after discovery.

1.4.2 Incidents shall be classified upon triage using the following severity scale:

- Low — no material impact on confidentiality, integrity, or availability; contained to a single, non-critical asset.
- Medium — limited impact affecting a single system or a small group of users; contained without client data exposure.
- High — significant impact, potential or confirmed exposure of client or Company data; requires immediate containment.
- Critical — severe, active compromise with confirmed data breach, ransomware, or loss of critical service availability; triggers full incident response activation.

1.4.3 The escalation chain for High and Critical incidents is: Reporting Employee → IT Security Lead → Chief Technology Officer → Executive Leadership, with client notification (where client data is involved) issued within 72 hours in line with applicable contractual and regulatory obligations.

1.4.4 All incidents, regardless of severity, shall be logged in the Company's incident register and reviewed at the following monthly security meeting for root-cause analysis and lessons learned.

1.5 Mapping to NIST Cybersecurity Framework (CSF) 2.0

While NIST SP 800-30 informs the risk assessment methodology used in this document, the policy's provisions can also be organized against the NIST CSF 2.0 core functions to show how governance activity relates to operational security outcomes:

- Govern — this Policy document itself, its annual review cycle, and Access Control clause 1.2.5 (quarterly access reviews).
- Identify — the Risk Register (Section 2), which inventories assets and associated risk.
- Protect — Access Control (1.2) and Password Policy (1.3) provisions, including MFA and least-privilege enforcement.
- Detect — the incident classification triage described in clause 1.4.2.
- Respond — the escalation chain in clause 1.4.3.

- Recover — addressed operationally through the Backup Storage risk treatment (Risk 11) rather than as a standalone policy clause; a dedicated Business Continuity Policy is recommended as future work.

2. Risk Assessment

2.1 Methodology

The risk assessment follows a NIST-aligned qualitative scoring model. Each identified asset is evaluated against a plausible threat and an associated vulnerability, and scored as:

$$\text{Risk} = \text{Likelihood (1–5)} \times \text{Impact (1–5)}$$

Likelihood reflects the probability of the threat exploiting the vulnerability within a 12-month period; Impact reflects the severity of consequence to the Company or its clients if realized. Resulting scores are classified as follows:

- 1–6 — Low
- 7–14 — Medium
- 15–20 — High
- 21–25 — Critical

A mitigating control is proposed for every risk scored High or Critical, in accordance with Company policy that such risks require an active treatment plan rather than passive acceptance.

2.2 Risk Register

Asset	Threat	Vulnerability	L	I	Score	Level	Mitigating Control
1. Developer laptops	Malware infection / device theft	No full-disk encryption enforced	3	4	12	Medium	Enforce BitLocker/FileVault + endpoint (EDR) agent on all devices
2. Client source code repositories	Unauthorized access / IP leak	Weak repo access controls, no branch protection	3	5	15	High	Enforce MFA, least-privilege repo roles, branch protection rules
3. CI/CD pipeline server	Supply-chain attack via injected code	Outdated pipeline software, hardcoded secrets	4	5	20	High	Secrets vault (e.g. Vault/KMS), regular patching, signed commits

Asset	Threat	Vulnerability	L	I	Score	Level	Mitigating Control
4. Cloud development environment	Public exposure of cloud resources	Overly permissive default IAM roles	4	5	20	High	Least-privilege IAM policies, periodic configuration audits
5. Employee email system	Phishing / business email compromise	No SPF/DKIM/DMARC, no attachment filtering	5	4	20	High	Implement SPF/DKIM/DMARC, phishing awareness training, email filtering
6. Client relationship / customer database (CRM)	Data breach / exfiltration	Database exposed with weak admin credentials, unencrypted at rest	5	5	25	Critical	Remove public exposure, encrypt at rest, harden credentials, deploy DB firewall
7. Office Wi-Fi network	Unauthorized network access	Shared WPA2 passphrase, no guest segregation	3	3	9	Medium	Migrate to WPA3-Enterprise, separate guest/staff VLANs
8. VPN remote access gateway	Credential stuffing / brute force	No MFA enforced on VPN login	3	5	15	High	Enforce MFA, monitor and alert on anomalous login patterns
9. HR / payroll system	Insider data misuse	Excessive access granted beyond HR staff	2	4	8	Medium	Apply strict RBAC, enable access audit logging
10. Physical office access (badge system)	Tailgating / unauthorized entry	No visitor sign-in or CCTV monitoring	2	3	6	Low	Enforce visitor log, install CCTV at entry points
11. Backup storage system	Ransomware encrypting backups	Backups stored on same network, no air-gap	3	5	15	High	Maintain offline/immutable backups, test restoration quarterly
12. Employee mobile devices (BYOD)	Data leakage via lost/stolen device	No Mobile Device Management (MDM) enforced	3	3	9	Medium	Enroll devices in MDM, enable remote wipe capability
13. Collaboration tools (chat/video)	Account takeover	No SSO or MFA on workspace accounts	2	3	6	Low	Enforce SSO with MFA across all workspace accounts
14. Domain registrar / DNS account	Domain hijacking	Single admin credential, no registry lock	1	5	5	Low	Enable registry lock, MFA, restrict account access
15. IT administrator / privileged accounts	Privilege escalation via credential compromise	Shared admin credentials, no PAM solution	3	5	15	High	Deploy PAM, enforce unique accounts, just-in-time access

L = Likelihood, I = Impact. Table shading reflects risk classification (green = Low, yellow = Medium, orange = High, red = Critical).

2.3 Likelihood & Impact Rationale

Each score in the Risk Register was derived by matching the asset's realistic threat-source and existing controls against the NIST SP 800-30 tier definitions for Likelihood (Table 3-4) and Impact (Table 3-5), then translating the matched tier to the 1–5 numeric scale. This traceable reasoning — rather than an unexplained number — is what makes each score defensible under review.

1. Developer laptops

Likelihood = Medium (3): opportunistic theft/malware, motivation moderate, but no disk encryption means controls don't impede loss once device is gone.

Impact = Medium (4): usually one dev's access/credentials exposed, costly to remediate but not company-wide.

2. Client source code repositories

Likelihood = Medium (3): IP has resale/competitive value, but repo login exists even though branch protection is missing.

Impact = High (5): leaked source code creates contractual liability and reputational harm central to the business.

3. CI/CD pipeline server

Likelihood = High (4): outdated software + hardcoded secrets means a moderately skilled attacker can succeed; controls are explicitly ineffective.

Impact = High (5): a supply-chain compromise here can affect every client relying on builds from this pipeline.

4. Cloud development environment

Likelihood = High (4): automated internet scanners actively probe for exposed cloud misconfigurations — no targeted skill required.

Impact = High (5): exposure can cascade into client cloud resources and secrets.

5. Employee email system

Likelihood = High (5): phishing is the most common attack vector globally; zero email-auth controls filter almost nothing.

Impact = Medium (4): business email compromise is serious but generally recoverable, not existential.

6. Client relationship / customer database (CRM)

Likelihood = High (5): publicly exposed databases are actively targeted by automated scanning tools regardless of attacker skill.

Impact = High (5): breach exposes client contract/contact data central to business trust.

7. Office Wi-Fi network

Likelihood = Medium (3): requires physical proximity (real constraint); WPA2 auth is a weak but real barrier.

Impact = Medium (3): grants network access but is not itself a data store.

8. VPN remote access gateway

Likelihood = Medium (3): credential stuffing is automated and common but still requires a matching valid credential.

Impact = High (5): success grants full internal network access.

9. HR / payroll system

Likelihood = Low (2): insider risk is largely opportunistic, not malicious, and some access control exists despite being excessive.

Impact = Medium (4): legally/financially serious but contained internally.

10. Physical office access (badge system)

Likelihood = Low (2): no obvious high-value physical target for a software consultancy; badge system still impedes casual entry.

Impact = Medium (3): a stolen unlocked laptop on-site is a plausible, non-trivial scenario.

11. Backup storage system

Likelihood = Medium (3): requires ransomware to already be present on the network — a conditional, not direct, path.

Impact = High (5): no air-gap means a successful hit removes the recovery path entirely.

12. Employee mobile devices (BYOD)

Likelihood = Medium (3): opportunistic loss/theft, low deliberate targeting.

Impact = Medium (3): typically limited to email/chat access, not core systems.

13. Collaboration tools (chat/video)

Likelihood = Low (2): lower-value target relative to other assets; login is still a barrier despite lacking SSO/MFA.

Impact = Low (3): exposure is limited to internal chat/meeting content.

14. Domain registrar / DNS account

Likelihood = Low (1): requires a specific, deliberate attacker interest — comparatively rare.

Impact = High (5): a hijack causes total outage and enables spoofing/phishing under the company domain.

15. IT administrator / privileged accounts

Likelihood = Medium (3): requires an initial foothold first, but is a highly attractive target once an attacker is inside.

Impact = High (5): compromise grants full administrative control across systems.

2.4 Summary of Findings

2.4.1 Of the 15 assets assessed, 1 was classified Critical, 5 High, 5 Medium, and 4 Low. The single Critical finding — the client relationship database — reflects the combination of high-value data

(client contact and contract information) with a currently weak security posture, and should be prioritized for immediate remediation.

2.4.2 A recurring theme across High-rated risks is the absence of Multi-Factor Authentication on sensitive systems (VPN gateway, email, backup access indirectly via admin accounts) and the lack of a centralized secrets/credential management solution across development infrastructure (CI/CD pipeline, cloud environment, privileged accounts).

2.4.3 It is recommended that Nexora prioritize remediation in the following order: (1) secure the client database, (2) enforce MFA universally across privileged and remote-access systems, (3) implement a Privileged Access Management (PAM) solution, and (4) establish immutable, air-gapped backups.